

SWYNEX

Web Security Review

Defensive Security Assessment of an Authorized Local OWASP Juice Shop Lab

Assessment Type	Defensive Web Security Review
Environment	OWASP Juice Shop – Local Authorized Lab
Application	http://localhost:3000
Tools	OWASP Juice Shop, Docker Desktop, Google Chrome, PowerShell, Windows
Scope	Local training application only

1. Objective

The objective of this assessment was to perform a defensive web security review of an intentionally vulnerable web application in an authorized local laboratory environment. The assessment focused on identifying common web security weaknesses, documenting evidence, evaluating potential risks, and providing remediation recommendations.

2. Tools Used

- OWASP Juice Shop
- Docker Desktop
- Google Chrome
- PowerShell
- Windows

3. Controlled Environment

The assessment was performed only against the locally hosted OWASP Juice Shop training application.

Application URL: http://localhost:3000

No third-party or unauthorized systems were targeted during this assessment.

4. Methodology

1. Started OWASP Juice Shop using Docker Desktop.
2. Accessed the application through the local localhost address.
3. Reviewed selected application functionality.
4. Performed controlled security tests against the intentionally vulnerable application.
5. Recorded successful challenge results and observed behavior.
6. Captured screenshots as evidence.

7. Documented the affected component, security risk, potential impact, and recommended remediation.
8. Limited all testing to the authorized local laboratory environment.

5. Finding 1 – SQL Injection / Authentication Bypass

Affected Component: Login / Authentication functionality

Description: A SQL injection-based authentication test was performed against the intentionally vulnerable Juice Shop login functionality. The authentication challenge was successfully completed, demonstrating that the vulnerable authentication mechanism could be bypassed in the training environment.

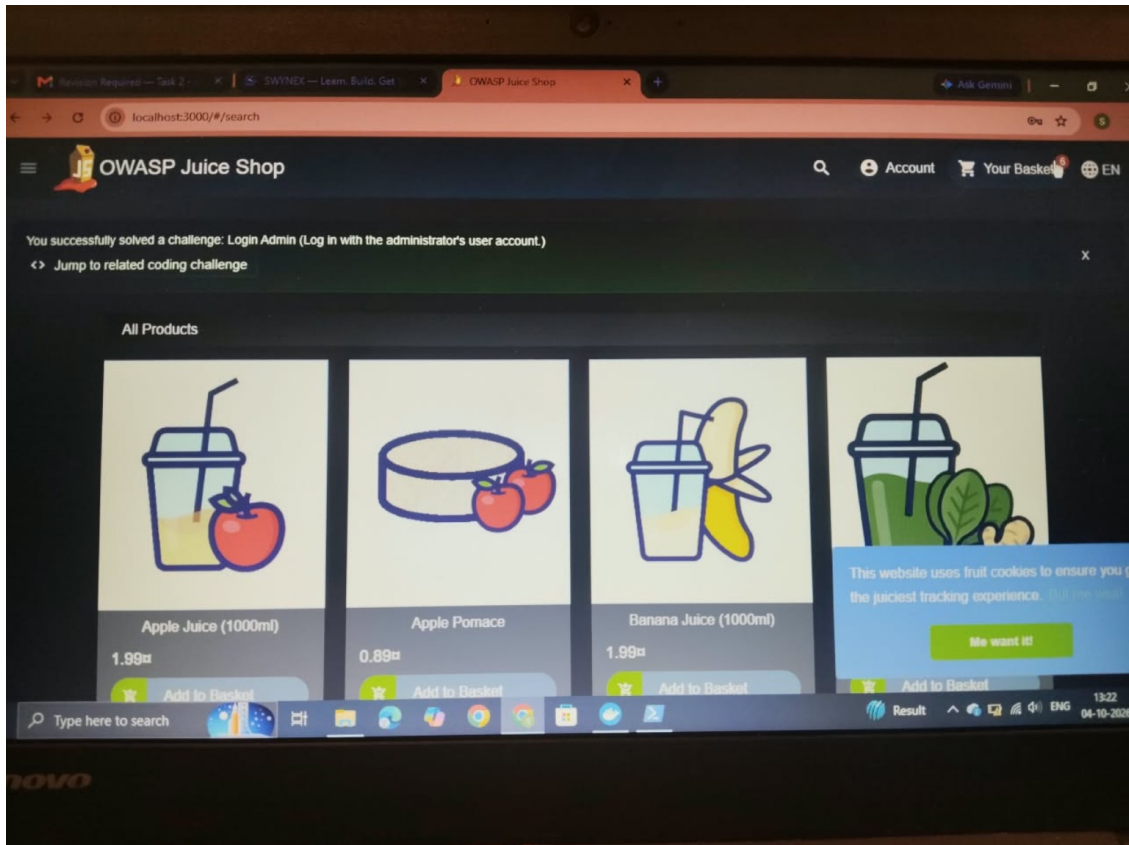
Evidence: The Juice Shop displayed a successful "Login Admin" challenge completion message.

Severity: High

Potential Impact: An authentication bypass vulnerability could allow an unauthorized user to access an account or privileged functionality without possessing valid credentials.

Recommended Remediation:

- Use parameterized queries and prepared statements.
- Never construct SQL queries directly from user-controlled input.
- Implement proper server-side input validation.
- Use secure authentication mechanisms.
- Apply least-privilege permissions to the database account.
- Monitor and log authentication failures and suspicious input.



Evidence 1 – Successful Login Admin challenge completion

6. Finding 2 – Cross-Site Scripting (XSS)

Affected Component: Search functionality

Description: A controlled XSS test payload was submitted through the search functionality of the intentionally vulnerable Juice Shop application. The test demonstrated that user-controlled input was being processed by the application's search functionality and was investigated as a potential client-side script injection issue.

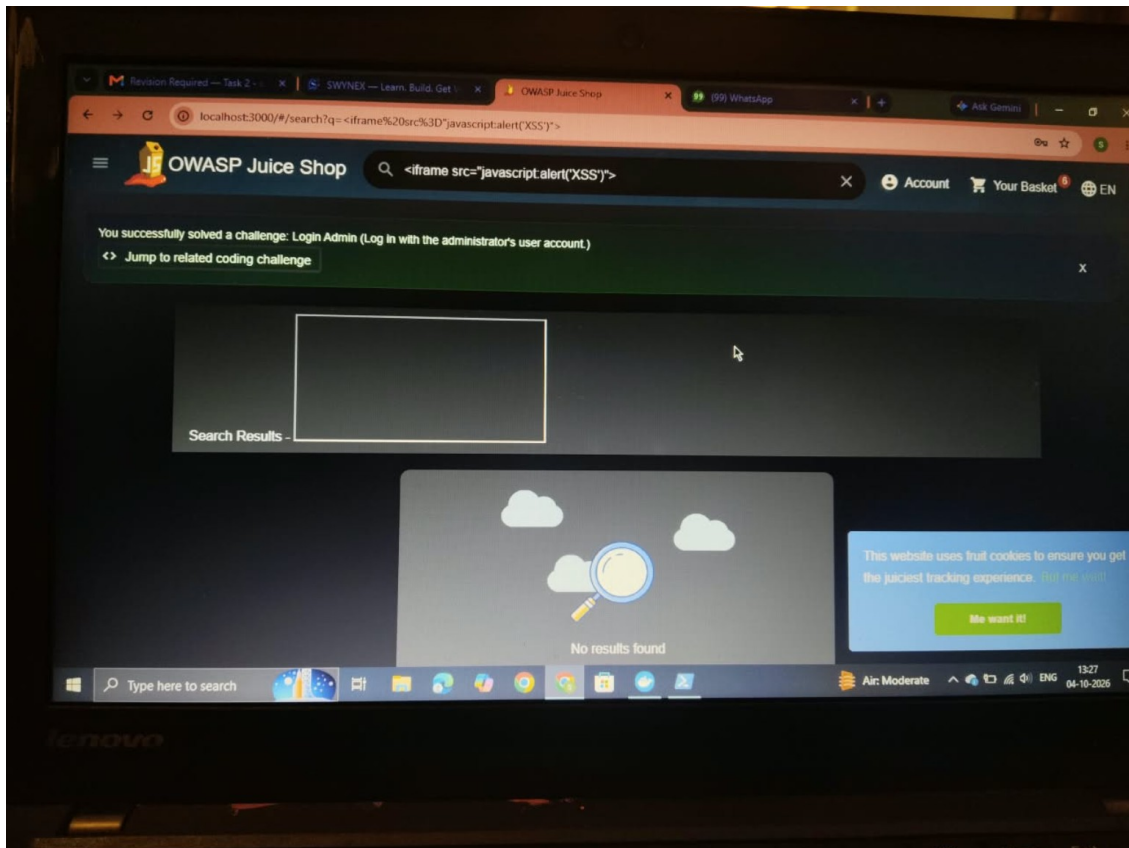
Evidence: The browser URL/search field contains the controlled XSS test payload. The supplied screenshot does not by itself prove JavaScript execution, so this report does not claim that an alert was successfully executed.

Severity: Medium

Potential Impact: A successful XSS vulnerability can allow attacker-controlled JavaScript to execute in another user's browser. Depending on the application's security controls and context, this could result in manipulation of displayed content, unauthorized browser actions, session-related attacks, or malicious redirection.

Recommended Remediation:

- Apply context-aware output encoding.
- Validate user-controlled input.
- Properly sanitize untrusted content where required.
- Avoid inserting untrusted input directly into HTML or JavaScript.
- Implement an appropriate Content Security Policy (CSP).
- Use secure framework APIs for rendering user-generated content.



Evidence 2 – Controlled XSS test payload in search functionality

7. Finding 3 – Exposed File / Information Disclosure

Affected Component: FTP/File area

Description: The file /ftp/legal.md was directly accessible through the web application. The file could be retrieved by navigating directly to its web-accessible path.

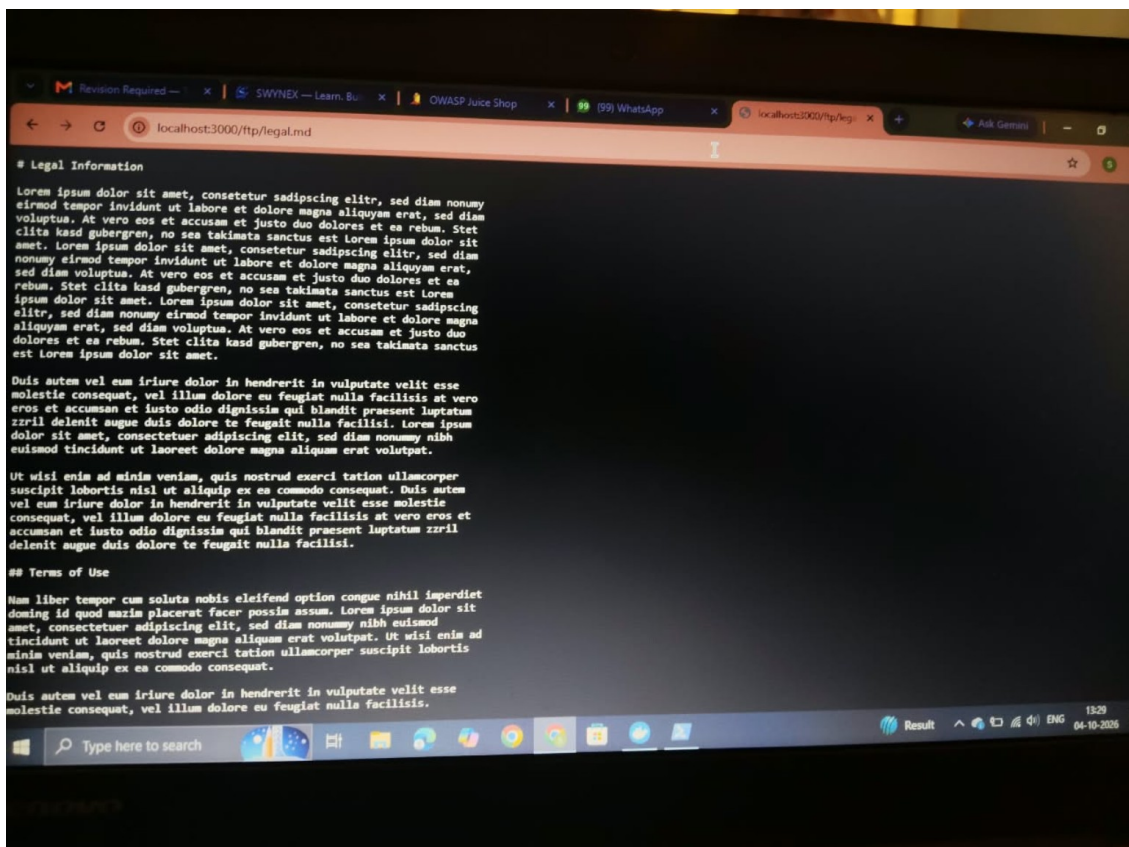
Evidence: The browser successfully displayed the contents of <http://localhost:3000/ftp/legal.md>, demonstrating direct retrieval of a web-accessible file.

Severity: Medium

Potential Impact: If sensitive files such as configuration files, backups, internal documents, source code, credentials, or other restricted resources are placed in a publicly accessible directory, unauthorized users may be able to retrieve them.

Recommended Remediation:

- Remove sensitive files from publicly accessible directories.
- Implement proper authorization checks.
- Restrict access to internal files.
- Review web-server file permissions.
- Disable unnecessary file exposure.
- Regularly audit publicly accessible resources.



Evidence 3 – Directly accessible /ftp/legal.md file

8. Risk Summary

Finding	Risk	Severity
SQL Injection / Authentication Bypass	Authentication may be bypassed	High

Cross-Site Scripting	User-controlled content may be processed as script	Medium
Exposed File / Information Disclosure	Web-accessible files may expose information	Medium

9. General Security Recommendations

- Use parameterized SQL queries.
- Validate user input on the server side.
- Apply context-aware output encoding.
- Implement strong authentication and authorization.
- Follow least-privilege principles.
- Restrict access to sensitive files.
- Avoid storing confidential files in web-accessible directories.
- Implement appropriate security headers and CSP.
- Keep application dependencies updated.
- Perform regular security assessments.
- Maintain logging and monitoring for suspicious activity.
- Use HTTPS/TLS in production environments.

10. Evidence Register

Evidence	Description
Finding-1-SQL-Injection-Login-Bypass.png	Successful Login Admin challenge completion
Finding-2-XSS.png	Controlled XSS test payload in search functionality
Finding-3-Exposed-File.png	Direct access to /ftp/legal.md

11. Limitations

This assessment was performed exclusively against the intentionally vulnerable OWASP Juice Shop application running in a local laboratory environment. No third-party, public, production, or unauthorized systems were tested. The findings therefore represent observations from the controlled training environment and should not be interpreted as vulnerabilities in any third-party application.

12. Conclusion

The defensive web security review identified and documented three security issues in the intentionally vulnerable OWASP Juice Shop training environment: SQL injection/authentication bypass, Cross-Site Scripting testing in the search functionality, and direct access to a web-accessible file. The exercise provided practical experience in security testing, evidence collection, risk assessment, and defensive remediation.

13. Submission Details

Repository Name	SWYNEX-Web-Security-Review
Assessment Environment	OWASP Juice Shop – Local Authorized Lab
Application	http://localhost:3000
Tools	OWASP Juice Shop, Docker Desktop, Google Chrome, PowerShell, Windows